

ClientScan

v2.0 · Security Platform

[Complete Tool Guide](#)

URL Scanner	Subdomain Discovery	Tech Fingerprint
Crawl Scanner	Dependency Scanner	API Fuzzer
AI Threat Model	Attack Simulation	PR Fix Bot
PDF / SARIF Reports	Compliance Dashboard	Scheduled Monitoring

nexoraai.app

2ool4techai@gmail.com

Getting Started

ClientScan is a local-first security scanning platform. It runs a web server on port 5555 and you use it entirely through your browser — no cloud account needed.

Installation

macOS	Open ClientScan-v2.0-mac.dmg → drag ClientScan to Applications → double-click to launch. Browser opens automatically at http://localhost:5555 .
Windows	Run ClientScan-v2.0-Setup.exe → follow the wizard → launch from Desktop or Start Menu. Browser opens automatically at http://localhost:5555 .
From Source	<code>cd clientscan && pip install reportlab requests && python3 api.py</code>

Running Your First Scan

Step 1	Enter the target URL in the TARGET bar at the top of the screen (e.g. https://yoursite.com)
Step 2	Choose scan depth: Quick (headers only, ~5s) · Standard (~15s) · Deep (full probes, ~60s)
Step 3	Click  Run Scan — results appear live in the feed
Step 4	Click any finding to expand it and see the plain-English explanation and fix

Setting Up AI (Optional)

Go to AI Providers in the sidebar. Add a free Groq key (console.groq.com) to enable all AI features — threat modelling, triage, attack simulation, and more. Keys are stored encrypted on your machine and never leave it.

Scan Depths Explained

Quick	HTTP security headers, TLS/SSL version check. Takes ~5 seconds.
Standard	Headers + TLS + exposed secrets in HTML + CORS + cookie flags. Takes ~15 seconds.
Deep	Everything in Standard plus active SQLi, XSS, SSTI injection probes and IDOR / privilege escalation tests. Takes 30–90 seconds depending on site size.

Discovery Features

Use these tools before scanning to fully map the attack surface of any target.

Crawl Scanner

Automatically discovers and scans every page on a website, not just the homepage. Uses breadth-first search, respects robots.txt, and seeds from sitemap.xml.

How to use	Sidebar → Crawl Scanner → enter URL → set Max Pages (up to 100) → Start Crawl
What it does	Follows all internal links, scans each page for vulnerabilities, shows which page each finding came from
Best for	Finding hidden admin pages, staging endpoints, and vulnerabilities that only appear on specific pages

Subdomain Discovery

Finds live subdomains using pure DNS resolution — no external services or API keys needed.

How to use	Sidebar → Subdomains → enter domain → Discover Subdomains
What it finds	Tests 60+ common names (api, admin, dev, staging, mail, cdn, vpn, git, etc.) concurrently. Returns each live subdomain with its IP address.
Best for	Finding forgotten staging servers, exposed admin portals, and shadow IT

Technology Fingerprint

Identifies every framework, CMS, CDN, WAF, and server software running on a site from HTTP headers and HTML patterns.

How to use	Sidebar → Tech Fingerprint → enter URL → Fingerprint
Detects	WordPress, React, Angular, nginx, Apache, Cloudflare, AWS CloudFront, jQuery, Bootstrap, Drupal, Django, Laravel, and 40+ more
Security hints	Shows known vulnerabilities and misconfigurations associated with each detected technology

Dependency Scanner

Checks npm and pip packages against the Google OSV vulnerability database. No API key needed — completely free.

Local file	Paste contents of package.json or requirements.txt → select type → Scan
GitHub repo	Paste a GitHub repo URL — ClientScan fetches and scans the dependency file automatically (public repos, no token needed)
Results	CVE ID, severity (CRITICAL/HIGH/MEDIUM/LOW), affected version, fixed version

API Fuzzer (OpenAPI / Swagger)

Tests REST APIs for security issues using their OpenAPI or Swagger specification.

How to use	Sidebar → API Fuzzer → enter spec URL (e.g. https://api.example.com/openapi.json) → Start Fuzz
Tests	Missing authentication · SQLi/XSS/SSTI injection · type confusion · required-field omission · server errors (500s)
Supports	OpenAPI 3.x and Swagger 2.x formats

AI Features

All AI features require one API key. Groq is free — get a key at console.groq.com in under 1 minute. Also supports OpenAI, Anthropic, Google Gemini, and local Ollama.

Threat Model	Generates a full threat model for any scanned site: attack surfaces, threat actors, data flows, and mitigations. Go to AI → Threat Model.
Vulnerability Triage	Click Explain next to any finding for a plain-English explanation: what it means, how an attacker exploits it, and exactly how to fix it.
Natural Language Scan	Describe what you want to test in plain English. AI translates it to a scan configuration. Example: 'check the login page for brute force weaknesses'. Go to AI → NL Scan.
Attack Chains	Identifies how individual vulnerabilities can be chained together for a larger attack. Shows the combined risk score and step-by-step exploitation path. Go to Attack Chains.
Attack Simulation	Simulates how a real attacker would approach the site: entry point, escalation path, data exfiltration, time estimate, and likelihood of success. Go to Attack Simulation.
Business Risk	Calculates financial exposure in USD: data breach cost, regulatory fines (GDPR), downtime cost, legal fees. Shows ROI of fixing each vulnerability. Go to Business Risk.
PR Fix Bot	For any selected vulnerability, AI generates a production-ready code fix and optionally opens a pull request on GitHub with the patch applied. Go to AI → PR Fix.
Compliance Explain	Explains exactly which OWASP, GDPR, and PCI-DSS requirements are failing and why, with plain-language remediation steps.

Reports & Compliance

Reports

PDF Report	Professional multi-page report with executive summary, full findings table, severity breakdown, and code-level fix recommendations. Go to Reports → Pentest Report.
Security Certificate	Pass/fail PDF certificate for sharing with clients or posting on your website. Go to Reports → Certificate.
SARIF Report	Machine-readable findings for uploading to GitHub Security tab or importing into other security tools. Go to Reports → SARIF.
JSON Report	Raw findings data for integration with dashboards, ticketing systems, or custom tooling. Available via the Export button.
Executive Scorecard	Single-page 0–100 score with A–F grade. Designed for CEO/board presentations. Go to Executive Scorecard.
Insurance Report	Estimated cyber insurance premium, recommended coverage amount, and a plain-language risk summary for brokers. Go to Insurance Report.

Compliance Dashboard

Scores your site automatically against four major frameworks based on scan findings.

OWASP Top 10 2021	All 10 categories scored individually — Broken Access Control, Injection, Cryptographic Failures, and more. Go to Compliance Report.
GDPR	Data encryption in transit, sensitive data exposure, cookie security and consent. Each failing check mapped to a specific article.
PCI-DSS	TLS/SSL configuration, access controls, data protection in transit. Relevant for any site handling payment data.
ISO 27001	Vulnerability management, access control policy, cryptographic controls. Scored from CRITICAL and HIGH severity findings.

Risk Trend & Virtual Patching

Risk Trend	Security score over time — shows whether your security posture is improving or degrading. Go to Risk Trend.
-------------------	---

Virtual Patching	Temporary WAF-style mitigation rules for critical findings while permanent fixes are being developed. Go to Virtual Patching.
------------------	---

Platform & Integrations

Scheduled Monitoring

Automatically re-scans a target on a schedule and emails you only when new vulnerabilities are found — not on every run.

Setup	Settings → Email → enter SMTP details, then Settings → Schedule → add a target URL and choose frequency
Frequency	Hourly · Daily · Weekly
Alerts	Email sent only for NEW findings since the last scan — no repeated noise

GitHub & CI/CD Integration

GitHub Actions	Download a ready-to-use workflow YAML from DevSecOps → GitHub Actions. Add it to .github/workflows/ to scan on every push and PR. Uploads SARIF to GitHub Security tab and fails the build if score < 70.
GitLab CI	Download a .gitlab-ci.yml snippet from DevSecOps → GitLab CI. Runs scan on main branch and merge requests.
PR Comment Bot	After scanning, post the full security report as a comment on any GitHub pull request. Requires a GitHub personal access token (repo scope) in Settings → GitHub.

Settings

AI Providers	Supported: Groq (free) · OpenAI · Anthropic · Google Gemini · Ollama (auto-detected on localhost:11434). Keys stored encrypted on your machine using PBKDF2-SHA256 + machine fingerprint.
Email / SMTP	Settings → Email. Works with Gmail, Outlook, or any SMTP server. Used for scheduled scan alerts. Password stored encrypted.
GitHub Token	Settings → GitHub. Personal access token for PR bot and PR fix features. Create at github.com/settings/tokens — needs repo scope.

Security & Privacy

Local-first	All scan data stays on your machine. Nothing is sent to any cloud service except the AI provider you choose.
--------------------	--

Encrypted keys	API keys and passwords are encrypted using PBKDF2-SHA256 (100k iterations) keyed to your machine's unique hardware fingerprint.
Rate limiting	10 scans per minute per IP to prevent accidental denial-of-service on target systems.
URL validation	Only http:// and https:// targets accepted. FTP, file://, and other schemes are rejected at the API boundary.

Connect & Support

ClientScan is part of the NexOraAI security platform — a suite of AI-powered tools built to make professional-grade security accessible to every developer and organisation.

Get in Touch

Website	nexoraai.app — platform overview, latest releases, and documentation
Email	2ool4techai@gmail.com — support, licensing enquiries, and partnerships
GitHub	github.com/2ool4techai-oss/Client-Scan — source code, issues, and contributions

Download & Install

macOS	ClientScan-v2.0-mac.dmg — drag to Applications, double-click to launch
Windows	ClientScan-v2.0-Setup.exe — run installer wizard, launch from Desktop
Source	git clone github.com/2ool4techai-oss/Client-Scan — pip install reportlab requests

Licensing & Future Plans

Current	ClientScan v2.0 is free and open-source for personal and commercial use
Pro (soon)	AI features, scheduled monitoring, and team access will move to a Pro tier — existing users will be grandfathered in free
Enterprise	Custom deployment, SSO, and dedicated support — contact us at 2ool4techai@gmail.com

Contributing

ClientScan is open source and welcomes contributions. Submit issues or pull requests at github.com/2ool4techai-oss/Client-Scan. Feature requests and bug reports are reviewed within 48 hours.

© 2025 NexOraAI · nexoraai.app · 2ool4techai@gmail.com · github.com/2ool4techai-oss/Client-Scan

ClientScan v2.0 is provided as-is for security research and authorised testing. Always obtain written permission before scanning systems you do not own.